

ONEALPHA REBUILD

Technical Development Documentation

Using Ever Gauzy as a reference for CRM, Audit Platform, and supporting modules

Prepared for management review and Agent-Harness execution

Version 1.0 | 13 September 2026 | Asia/Jakarta

Document control

Item	Value
Purpose	Define the technical strategy and governed delivery plan for rebuilding OneAlpha.
Reference	Ever Gauzy open-source ERP/CRM/HRM/ATS/PM platform.
Primary source of truth	Approved OneAlpha and CBQA Global requirements.
Execution model	Local-first Agent Harness with isolated worktrees and human approval gates.
Scope	CRM, Proposal, Project, Audit Platform, Personnel/Competency, Documents, Certificate, Reporting, Integrations.
Status	Proposed baseline. Discovery must validate all assumptions.

Management decision requested

- Approve the reference-plus-rebuild strategy.
- Approve a read-only discovery phase as the first gate.
- Authorize repository onboarding and architecture assessment.
- Require legal review before copying Gauzy source code or packages.
- Require human approval for schema migration, staging deployment, protected merges, and production changes.

1. Executive technical position

Ever Gauzy is suitable as a reference for generic platform capabilities and engineering patterns. A direct fork or wholesale replacement would create domain, licensing, migration, and operational risks. OneAlpha should rebuild around its CBQA workflow and use Gauzy selectively for platform mechanics.

Decision area	Recommendation	Reason
Product strategy	Reference + rebuild	Preserves CBQA domain fit while improving platform foundations.
Architecture	Modular monolith first	Reduces distributed-system overhead and keeps transactions consistent.
Workflow ownership	Backend-driven state machine	Prevents frontend/backend drift and bypassed transitions.
Authentication	Retain Keycloak 25 integration	Existing internal/external identity model is a critical dependency.
Audit service	Keep Go Audit as bounded service if justified	Avoids an unnecessary rewrite during the first increment.
Generic modules	Build only when business case is approved	Prevents the rebuild from becoming an uncontrolled ERP program.
AI/MCP	Read-only by default	Protects business data and production state.

2. Scope and boundaries

The target platform connects the commercial lifecycle to the certification lifecycle. Generic modules must support the flow without owning CBQA policy.

In scope

- CRM: leads, contacts, companies, clients, proposals, proposal items, sales pipeline.
- Commercial-to-delivery: standards, schemes, sectors, sites, multi-site, methodology, audit date, project.

- Audit Platform: Application Review, Scheduling, Auditor, Audit Execution, Technical Review, Decision, Certificate Issuance.
- Personnel: qualifications, competencies, sectors, rates, availability, impartiality.
- Documents: evidence, templates, reports, certificates, controlled outputs.
- Platform: tenant context, roles, permissions, audit log, notifications, calendar, reporting, integrations.
- Migration: Audit-Q/current OneAlpha mapping, dry-run, reconciliation, pilot, UAT, rollout.

Out of scope for the first increment

- Wholesale replacement of every Gauzy module.
- Payroll, inventory, manufacturing, and generic accounting unless separately approved.
- Language rewrite of existing OneAlpha or Go Audit without an ADR.
- Direct production migration or deployment by an agent.
- Unrestricted agent mutation through MCP.

3. Gauzy reference assessment

Gauzy capability	OneAlpha application	Decision
Multi-tenant organizations	Master Tenant and tenant-scoped access	Adapt
Roles and permissions	Role/action policy and approval control	Adapt
CRM and proposals	CBQA CRM and proposal lifecycle	Adapt
Projects and tasks	Audit task generation and operational work	Adapt
Documents and knowledge	Evidence, controlled documents, audit reports	Adapt
Dashboards and analytics	Executive and Staff Operational dashboards	Adapt
Plugins/integrations	Integration adapters and extension points	Adapt
REST/GraphQL APIs	Headless API contracts	Evaluate; REST first
Redis/OpenSearch/object storage	Performance, search, private evidence files	Add by measured need
MCP server	Agent-assisted reporting and controlled operations	Read-only first
Payroll/inventory/generic ERP	Not required for initial OneAlpha rebuild	Defer
Gauzy source code/packages	Potential implementation reference	Legal/license gate

Technical conclusion

Gauzy demonstrates a broad, active TypeScript platform with tenant support, APIs, plugins, desktop applications, analytics, and cloud deployment patterns. The project also has substantial infrastructure and licensing considerations. The rebuild should extract concepts and contracts before considering any source reuse.

4. Target architecture

The target architecture separates reusable platform capabilities from CBQA policy modules. The initial deployment can remain a modular monolith with explicit boundaries and event interfaces.

Component	Responsibilities	Primary data
Identity & Access	Keycloak integration, OIDC, roles, actions, tenant context	Users, roles, permissions, sessions

Tenant / Organization	Master Tenant, tenants, departments, teams, scoping	Tenants, memberships, settings
CRM & Commercial	Leads, clients, proposals, pipeline, sales/invoice links	Companies, contacts, leads, proposals
Proposal / Project	Scope, standards, sites, methodology, dates, project creation	Proposal revisions, projects, audit dates
Audit Workflow	State machine, transitions, locks, revisions, approvals	Audit cases, stages, transitions, tasks
Personnel / Competency	Qualifications, sectors, rates, availability, impartiality	Personnel, competency, qualification
Documents / Certificate	Evidence, templates, generated outputs, signatures	Files, versions, certificates, numbering
Reporting	Metric definitions, dashboards, exports	Read models, aggregates, reports
Integration Layer	OneDatahub, Go Audit, email, storage, external services	Mappings, events, integration logs

Architecture rules

- Every tenant-sensitive request resolves tenant context before data access.
- Every workflow mutation checks actor, tenant, current state, required fields, and transition policy.
- Every cross-module event has an idempotency key and correlation ID.
- Frontend renders backend-provided allowed actions and lock state.
- Generated documents retain template version, input snapshot/hash, actor, and timestamp.
- External integrations use adapters and contract tests rather than direct domain coupling.

5. Authentication and authorization

The existing identity architecture must remain explicit and environment-specific.

Flow	Provider	Controls
Internal staff	Microsoft Entra SSO through Keycloak 25	OIDC client, issuer, audience, role mapping
External customer	OneDatahub POST signin through Keycloak integration	Separate client and redirect configuration
Application clients	AuditQ, OneAlpha, CRM, related modules	Client-specific scopes and audiences
Staging	Staging identity and OneDatahub endpoints only	Configuration validation blocks production URL

Authorization model

- RBAC for role membership.
- Action-level policies for view/create/edit/submit/approve/revise/issue/export.
- Tenant and organization scope on every query.
- Stage-specific permission checks.
- Separation of Auditor, Technical Reviewer, Certification Authority, and Issuer where required.
- Audit log for every permission-sensitive mutation.
- Automated IDOR and cross-tenant access tests.

6. CRM and audit domain model

The core data model must make the commercial-to-audit relationship explicit.

Entity	Key relationships	Important invariants
--------	-------------------	----------------------

Tenant	has users, organizations, clients, proposals, audits	All child records are tenant-scoped.
Company / Client	has contacts, sites, proposals, certificates	Client identity must be stable across cycles.
Proposal	has revisions, items, standards, sectors, sites, methodology	Approved revision is immutable except through controlled revision.
Project	created from approved proposal	Retains source proposal/revision reference.
Audit Case	belongs to project and cycle	Owns current stage and transition history.
Audit Stage	belongs to audit case	Only active stage is editable.
Personnel	has qualification, competency, availability, impartiality	Assignment requires policy validation.
Audit Task	belongs to audit/stage/person	Creation is idempotent and source-linked.
Certificate	belongs to cycle/audit and issuance history	Issued versions are immutable.
Document	belongs to case/certificate and version chain	Access is tenant- and role-controlled.

7. Workflow state machine

The backend owns the workflow state and returns the state, allowed actions, required data, lock state, and revision options to the frontend.

Common lifecycle

DRAFT → READY_FOR_APPLICATION_REVIEW → APPLICATION_REVIEW_IN_PROGRESS → READY_FOR_SCHEDULING → SCHEDULED → AUDIT_IN_PROGRESS → READY_FOR_TECHNICAL_REVIEW → TECHNICAL_REVIEW_IN_PROGRESS → READY_FOR_DECISION → DECISION_IN_PROGRESS → READY_FOR_ISSUANCE → CERTIFICATE_ISSUANCE_IN_PROGRESS → COMPLETED

Transition contract

Field	Requirement
currentState	Server-derived current state.
allowedActions	Actions allowed for the actor and tenant.
requiredFields	Fields required to execute the selected action.
requiredDocuments	Documents required by standard and stage.
assignedActors	Responsible person/role and independence constraints.
lockState	Editable/read-only/locked with reason.
revisionContext	Origin stage, reason, actor, timestamp, and target stage.
auditTrail	Immutable transition record with correlation ID.

Domain rules

- Integrated/Combined Audit uses one Application Review and one coherent audit flow.
- Completed stages become read-only unless Need Revision opens a controlled path.
- Audit date edits recalculate downstream tasks without creating duplicates.
- Transfer Audit takes precedence before Surveillance or Recertification.
- Certificate preparation may proceed in parallel when approved, but issuance remains controlled.
- Standard-specific policies extend the common workflow and cannot bypass common authorization.

8. Module delivery plan

Phase	Primary outputs	Exit gate
0. Harness readiness	Repos, AGENTS.md, worktrees, task contracts, health checks	No-op task completes safely.
1. Discovery	FE/BE/API/database/workflow inventory and Gauzy matrix	Human approval of baseline.
2. Foundation	Identity, tenancy, policies, audit log, errors, files, jobs	Isolation and auth tests pass.
3. CRM	Lead → proposal → approval → project → audit date	Proposal/project E2E passes.
4. Audit core	AR → Scheduling → Audit → TR → Decision → Issuance	Common workflow E2E passes.
5. Policy modules	ISO, ISCC, LVV, LATIK, Transfer Audit	Policy tests and UAT evidence pass.
6. Outputs	Documents, certificates, reports, dashboards, client view	Visual/export regression passes.
7. Migration	Dry run, reconciliation, pilot, C1–C9 UAT	Business sign-off.
8. Rollout	Release, backup/restore, monitoring, rollback runbook	Production approval.

9. Agent-Harness execution model

The Agent Harness coordinates specialist agents in isolated worktrees. It must produce reviewable output rather than treating agent completion as approval.

Agent	Responsibilities	Required handoff
Architect	Boundaries, ADRs, contracts, design decisions	ADR, diagram, assumptions, risks
Frontend	Routes, forms, stepper, guards, UX, exports	Changed files, screenshots, tests
Backend	Entities, APIs, policies, transitions, events	API diff, migrations, tests, invariants
QA	Test plan, automation, regression, UAT	Evidence, failed cases, risk status
Reviewer	Code quality, security, scope, maintainability	Review report and blocking findings
DevOps	CI/CD, environments, Docker, observability	Runbook, config diff, deployment evidence
Documentation	PRD, API docs, traceability, release notes	Updated docs and coverage matrix

Approval levels

Level	Examples	Required approval
A0	Read-only discovery and documentation	Agent completion
A1	Non-breaking code and UI improvements	Reviewer
A2	API, schema, permission, workflow changes	Architect + Reviewer + QA
A3	Migration, staging deployment, external integration	Explicit human approval
A4	Production, protected merge, destructive action	Explicit human approval and release record

10. API and integration standards

- Use versioned, documented API contracts.
- Return consistent errors with code, message, field errors, correlation ID, and timestamp.
- Use pagination, filtering, sorting, and explicit export limits.
- Use idempotency keys for task creation, notifications, document generation, and integrations.
- Use optimistic locking or version checks for proposals, audit stages, and certificates.
- Emit domain events only after the transaction reaches a valid state.
- Use contract tests for Keycloak, OneDatahub, Go Audit, storage, and notification adapters.
- Do not expose internal database IDs where a stable public reference is required.

11. Database and migration strategy

Database changes are high-risk actions and require a human gate. The migration system must support dry-run, validation, reconciliation, and controlled rollback planning.

Control	Implementation expectation
Source mapping	Preserve source system ID, target ID, source type, migration batch, and status.
Dry run	Validate mapping, constraints, duplicates, missing references, and file availability without commit.
Reconciliation	Compare counts, totals, status distribution, relationships, and sample records.
Repeatability	Migration can be safely re-run using idempotency and mapping tables.
Historical integrity	Preserve actors, dates, approvals, documents, certificate references, and revisions.
Rollback	Define compensating action or restore procedure before production execution.
Observability	Record batch ID, duration, failures, retries, and unresolved records.

12. Documents, certificates, and exports

- Use private object storage with signed, expiring download URLs.
- Apply role, tenant, case, and certificate access checks before download.
- Store document version, template version, generated-by, generated-at, source hash, and approval status.
- Do not overwrite issued certificates.
- Add PDF, XLSX, and PPTX visual regression fixtures.
- Capture certificate numbering rules per standard and service.
- Support additional locations, SOA, material mapping, GHG/ISCC EU waste/SAI FSA fields where applicable.
- Test FAPP-01 through FAPP-08 and approved audit report/summary outputs.

13. Security and compliance checklist

- No production secrets in code, prompts, logs, or artifacts.
- Staging cannot point to production OneDatahub or Keycloak endpoints.
- Tenant isolation tests cover list, detail, search, export, file, and mutation endpoints.
- Token validation checks issuer, audience, signature, expiry, and required claims.
- File access prevents IDOR and unauthorized signed URL reuse.

- Agent/MCP operations are allowlisted and read-only by default.
- Dependency and license scan runs before adding Gauzy source or packages.
- Use HTTPS/WSS in all non-local environments.
- Security findings use a separate severity workflow and are not hidden in feature summaries.

14. QA and UAT strategy

Testing must validate both technical correctness and certification workflow behavior.

Layer	Coverage
Unit	State transitions, policy rules, competency, calculations, numbering, mappings.
Integration	Database, Keycloak, OneDatahub, Go Audit, storage, queue, notifications.
Contract	FE/BE, external API, document generation, integration adapters.
E2E	CRM through certificate for ISO, ISCC, LVV, LATIK, integrated audit, transfer.
Security	Tenant isolation, IDOR, token abuse, file access, CORS/CSRF, secret exposure.
Performance	Dashboards, search, client list, certificate search, bulk exports.
Visual	Critical UI, PDF, XLSX, PPTX, certificate templates.

Regression baseline

Use C1–C9 as the first regression baseline. Current status context records C1 and C5 as closest to UAT readiness, C9 requiring ISCC formatting retest, and C2–C4/C6–C8 requiring multi-standard certificate-drafting enhancement. The harness must update status only with test evidence.

15. Observability and operations

- Health and readiness probes for API, database, queues, storage, and external identity dependencies.
- Correlation ID from frontend request through backend, job, integration, and document generation.
- Metrics for workflow throughput, failed transitions, queue latency, document failures, and tenant errors.
- Structured logs with PII minimization.
- Alerts for authentication failures, cross-tenant access attempts, migration errors, and certificate generation failures.
- Backup and restore verification before rollout.
- Runbooks for staging restart, failed deployment, migration pause, rollback, and certificate output recovery.

16. Initial backlog

ID	Task	Agent lead	Gate
ONEALPHA-DISCOVERY-001	Read-only current-state inventory and Gauzy adoption boundary	Architect	A0 then human review
ONEALPHA-FOUNDATION-001	Tenant context, action policy, audit log, error contract	Backend	A2
ONEALPHA-AUTH-001	Keycloak and OneDatahub environment validation	Backend/DevOps	A2/A3

ONEALPHA-CRM-001	Proposal, revision, approval, methodology, multi-site	Backend/Frontend	A2
ONEALPHA-AUDIT-001	Common audit case and backend state machine	Backend/QA	A2
ONEALPHA-AUDIT-002	Stepper, locks, allowed actions, Need Revision	Frontend/Backend	A2
ONEALPHA-COMP-001	Competency-based assignment and impartiality	Backend/QA	A2
ONEALPHA-DOC-001	Controlled evidence and certificate generation	Backend/Docs/QA	A2
ONEALPHA-UAT-001	C1–C9 regression and evidence pack	QA	A3
ONEALPHA-MIG-001	Dry-run migration and reconciliation	DevOps/Backend/QA	A3

17. Definition of Done

- Requirement and scope are traceable to an approved source.
- Backend invariants and authorization rules are implemented.
- Frontend reflects backend workflow state and allowed actions.
- Database changes have migration, rollback, and data-impact notes.
- Tenant isolation and security tests pass.
- Required unit, integration, contract, E2E, and visual tests pass.
- Reviewer has inspected changed files and dependencies.
- Documentation, API contract, and runbook are updated.
- Staging execution is repeatable.
- UAT evidence is attached.
- Critical/high risks are visible and assigned.
- Required human approval is recorded.

18. Final recommendation

Approve a controlled reference-plus-rebuild program. Start with read-only discovery, then stabilize the foundation before rebuilding CRM and the common Audit lifecycle. Add ISO, ISCC, LVV, LATIK, documents, dashboards, and migration only after the common contracts are proven.

The first task for the harness is ONEALPHA-DISCOVERY-001. It must not modify code, migrate data, deploy, or use production credentials.

Reference links

- Ever Gauzy repository: <https://github.com/ever-co/ever-gauzy>
- Ever Gauzy documentation: <https://docs.gauzy.co/>
- Ever Gauzy releases: <https://github.com/ever-co/ever-gauzy/releases>